Guía del formador — MongoDB 8.0: indexación y seguridad

Presentación de la formación

Los manuales de indexación y seguridad se han preparado para personas sin experiencia previa administrando MongoDB. Su objetivo no es memorizar comandos, sino comprender por qué existe cada mecanismo, cuándo conviene usarlo, qué ocurre al ejecutarlo y cómo verificar su funcionamiento.

La colección de ventas, los usuarios y los certificados pertenecen a un **laboratorio ficticio**. No se utilizarán datos personales ni infraestructura de producción.

Ruta principal: empezar por documentos y consultas, medir una búsqueda antes y después de un índice; estudiar un compuesto con igualdad, ordenación y rango; pasar a autenticación y roles; cerrar con la diferencia entre TLS e identidad X.509.

Ruta de ampliación: cardinalidad y selectividad, arrays y multikey, búsqueda de texto, geoespaciales, hashed, unicidad parcial, TTL, consultas cubiertas, diagnóstico de índices, roles personalizados, gestión de permisos y protección de secretos.

La extensión de los manuales supera una sesión corta. El objetivo no es «pasar por todas las páginas», sino que el alumnado complete la ruta principal con comprensión. Las unidades de ampliación permiten profundizar después.

Cómo evaluar comprensión sin confundirla con copiar comandos

Antes de crear un índice, pregunte al alumno **qué consulta concreta quiere mejorar**. Después de crearlo, pida explicar qué plan utilizó MongoDB y cuántos documentos o claves examinó. Si el estudiante solo dice que «ahora es más rápido», pídale diferenciar tiempo medido y esfuerzo lógico.

En seguridad, solicite siempre al menos una prueba positiva y una negativa: lectura permitida a la cuenta lectora y escritura denegada. **Que una inserción falle con Unauthorized puede ser el resultado correcto** si el rol estaba definido para prohibirla.

Para valorar una práctica pida cinco evidencias:

1. Estado inicial de datos o usuarios.
2. Comando ejecutado, indicando si fue en PowerShell/Bash o en mongosh.
3. Resultado esperado formulado antes de ejecutar.
4. Resultado observado, omitiendo secretos.
5. Explicación causal de la diferencia, si la hubiera.

Un mensaje `[OK]` confirma que el programa verificó una condición; no demuestra por sí solo que el alumno la comprendió.

Preparar el entorno con antelación

Compruebe Docker Desktop o Docker Engine con Compose. El repositorio contiene `compose.yaml` y `.env.example`. Cree un archivo local `.env`, cámbiele las contraseñas de ejemplo y no lo publique. Verifique la disponibilidad de los puertos locales 27017, 27018 y 27019.

Los servicios son:

- `mongo-indices`: documentos de ventas, búsqueda y distintos tipos de índices.
- `mongo-seguridad`: cuentas SCRAM, roles y acciones denegadas.
- `mongo-tls`: servidor que exige TLS y permite probar X.509.

El estado de las bases se almacena en **volúmenes Docker con nombre**. `docker compose stop` detiene un servicio sin borrar sus datos. `docker compose down` retira los contenedores y las redes creadas, pero conserva los volúmenes con nombre por defecto. `docker compose down --volumes` sí elimina esos volúmenes y, con ellos, cuentas y documentos ficticios. Enseñe esta diferencia antes de proponer cualquier «reinicio».

Control previo

```
docker compose config
docker compose up -d --wait mongo-indices
docker compose ps
```

Si falla el primero, revise `.env` y la sintaxis de Compose. Si falla el segundo, compruebe que Docker esté iniciado y los puertos libres. No dé por hecho que un error de contenedor es un problema de autenticación.

Ruta docente A: índices

A1. Comprender los datos

Muestre una venta con `numero`, `clienteId`, `estado`, `fecha` e `importe`. Pregunte si el alumno distingue un filtro de una proyección y de una ordenación. La respuesta es necesaria antes de introducir `explain`.

A2. Encontrar una venta

En PowerShell o Bash, en la raíz del repositorio:

```
docker compose exec -T -e VENTAS=200000 mongo-indices mongosh --quiet --file /lab/
01_cargar_ventas.js
docker compose exec -T mongo-indices mongosh --quiet --file /lab/02_antes.js
```

Antes de seguir, cada estudiante debe localizar `nReturned` y `totalDocsExamined`. Pregunte por qué pueden ser tan diferentes.

A3. Crear el índice y explicar el cambio

```
docker compose exec -T mongo-indices mongosh --quiet --file /lab/03_crear_indices.js
docker compose exec -T mongo-indices mongosh --quiet --file /lab/04_despues.js
```

Exija comparar la misma consulta. Los milisegundos no deben presentarse como un factor universal de aceleración; utilice plan y contadores para argumentar la reducción de trabajo.

A4. Dos índices compuestos

Traduzca «ventas pagadas, superiores a 500, ordenadas por fecha» a una consulta. Señale igualdad, ordenación y rango. Muestre los índices ESR y ERS con el archivo `lab/15_compuestos_guiado.js`. No enseñe la regla ESR como si siempre se debiera aplicar sin medir.

A5. Ampliaciones recomendadas

En función del ritmo de clase: `$elemMatch` sobre arrays, texto, índices 2dsphere, hashed, unicidad parcial y TTL. Una ampliación se considera útil cuando el estudiante puede explicar qué problema resuelve y qué problema no resuelve.

Ruta docente B: seguridad

B1. Autenticación versus autorización

Plantee dos preguntas independientes: «¿quién eres?» y «¿qué puedes hacer?». En la base `curso_seguridad` el administrador prepara un documento ficticio y dos cuentas: `lectorlab` con rol `read` y `escritorlab` con rol `readWrite`.

B2. Cuatro pruebas imprescindibles

El alumno debe observar:

1. Una lectura sin autenticar, rechazada.
2. Una lectura como `lectorlab`, permitida.
3. Una inserción como `lectorlab`, rechazada.
4. Una inserción como `escritorlab`, permitida.

Pregunte por qué la tercera prueba demuestra una configuración correcta. Si el grupo responde «porque el usuario es incorrecto», aclare que la cuenta sí está autenticada, pero la operación supera sus privilegios.

B3. TLS no concede permisos

Con certificados de laboratorio generados mediante `scripts/generar-certificados.sh`, `mongo-tls` debe rechazar una conexión sin TLS y aceptar una conexión TLS que verifique la CA. Un `ping` positivo no demuestra lectura de datos protegidos.

B4. X.509

Explique la diferencia entre el certificado de servidor y el de cliente. La identidad del certificado de alumno se registra en `$external`, con un rol de lectura. Debe leer un documento y recibir un rechazo al escribir.

B5. Temas conceptuales

LDAP, cifrado nativo en reposo, gestión empresarial de claves, recuperación y auditoría avanzada deben explicarse como decisiones de arquitectura y producto. No afirme que el contenedor Community ejecuta funciones que no están disponibles en su edición.

Resolver fallos sin añadir nuevos

Pida al alumno que identifique antes de repetir cualquier comando:

- qué pretendía conseguir;
- qué servidor y base estaba utilizando;
- si escribía en la terminal del host o dentro de mongosh;
- qué esperaba ver;
- qué mensaje obtuvo;
- qué condición concreta podría investigar.

Ejemplos:

El script dice que ya hay índices: la primera medición necesita datos sin índices secundarios; recargue únicamente la colección ficticia y explique que la recarga destruye esos índices.

Unauthorized al insertar como lector: no dé permisos de administrador. Compruebe primero que la lectura funciona y explique la denegación esperada.

Fallo TLS: compruebe el certificado, la CA, el nombre de host y la fecha. No desactive validación de certificados para conseguir una demostración engañosamente satisfactoria.

Una consulta devuelve cero resultados: verifique datos, colección y filtro antes de atribuirlo al índice.

Preguntas de evaluación y respuestas

1. ¿Una búsqueda que devuelve un documento, pero examina 200.000, está necesariamente mal? No. Puede ser correcta respecto a su resultado, pero costosa respecto al trabajo. La decisión de optimizar depende de consulta, volumen y frecuencia.

2. ¿Por qué no crear índices para cada campo? Por su consumo de espacio y mantenimiento; una aplicación también inserta, modifica y elimina documentos.

3. ¿Por qué puede necesitar SORT un índice ERS? Porque ordenar primero por un rango de importe puede no conservar el orden global de fechas solicitado entre distintos importes.

4. ¿Qué demuestra una escritura denegada a un lector autenticado? Que se está aplicando la autorización sobre esa acción, siempre que la identidad y el contexto estén bien comprobados.

5. ¿Por qué `ping` con TLS no demuestra permisos de datos? Porque responde a una comprobación de conectividad y canal, no a una autorización sobre una colección.

Cierre

El alumnado debe poder resolver un caso nuevo, no solo repetir el caso visto: formular una consulta, elegir un índice candidato, medir su plan, asignar un rol mínimo y comprobar al menos una operación que deba ser denegada. La formación se completa cuando puede justificar las decisiones con observaciones y comprender los límites de lo verificado.